

Narrativa Explicativa – GQM + PRAGMATIC para Indicadores MITRE ATT&CK

1. De la política a la consola (y vuelta)

Los objetivos nacionales de ciberseguridad suenan solemnes en las estrategias: “aumentar la resiliencia”, “proteger infraestructuras críticas”, “alinearse con el panorama de amenazas europeo”. [web:66] [web:43]

El problema aparece cuando hay que traducir tanta épica en métricas que se puedan leer sin necesidad de un oráculo.

MITRE ATT&CK ofrece un lenguaje común para describir lo que hacen los adversarios; ENISA, por su parte, ofrece el mapa de las campañas que efectivamente nos golpean. [web:29] [web:66]

El marco GQM + PRAGMATIC es el puente entre el discurso estratégico y los datos humildes de la consola del SOC.

2. GQM: empezar por la pregunta incómoda

GQM obliga a ordenar el pensamiento:

- Goal: ¿Queremos reducir incidentes graves? ¿Aumentar la capacidad de contener movimiento lateral? ¿Mejorar la visibilidad de ataques sin malware? [web:26] [web:66]
- Question: ¿Qué tengo que saber para saber si me acerco o me alejo de ese objetivo?
- Metric: ¿Qué puedo medir, con lealtad a la realidad, para responder a la pregunta?

Aplicado a ATT&CK, la conversación cambia de “¿cuántas reglas tengo?” a “¿qué porcentaje de técnicas que realmente me atacan estoy viendo y en cuánto tiempo?”. [web:16] [web:22] [web:66]

3. PRAGMATIC: una métrica vale lo que mide y lo que cuesta

El método PRAGMATIC nos recuerda que no todas las métricas nacen iguales:

- Algunas son predictivas, otras meramente decorativas.
- Unas son accionables (mueven presupuesto, cambian procesos), otras se recitan para rellenar slides.
- La genuinidad es clave: métricas que invitan al “gaming” (inflar cifras) son peligrosas.

Al puntuar cada métrica ATT&CK con los nueve criterios PRAGMATIC (Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente y Rentable) se filtra el ruido. [web:29]

Lo que queda es un conjunto de indicadores que justifican el esfuerzo de recogida y, sobre todo, las discusiones que provocan.

4. Qué indicadores “sobreviven” a GQM + PRAGMATIC

En el cruce de GQM y PRAGMATIC emergen unos sospechosos habituales:

- Cobertura de tácticas y técnicas relevantes: quién ve qué y en qué sectores.[web:29][web:66]
- Brecha entre cobertura declarada y validada: cuánto nos mentimos (sin mala intención).[[web:16][web:22]
- Tiempos de detección/contención/recuperación por táctica crítica: si el atacante corre un sprint y nosotros hacemos yoga lento.[web:26][web:66]
- Uso real de CTI y alineación con ENISA ETL: si nuestros casos de uso reflejan el mundo real o una novela fantástica.[web:66][web:43]
- IGM y ROI: para conversar con ministros, consejeros y CFO sin que huyan de la sala.[web:50][web:53]

Cada uno de estos indicadores ha sido “pasado por la trituradora” PRAGMATIC: se mantiene aquello que, además de sonar bien, ayuda a tomar decisiones no triviales.

5. Cómo usar este marco sin perder la cordura

Algunas sugerencias pragmáticas:

1. No medirlo todo a la vez.
Empieza con 3–5 indicadores de alta puntuación PRAGMATIC (por ejemplo, cobertura de técnicas relevantes, MTTD/MTTR en cadenas críticas y brecha declarada/validada).
2. Alinea los indicadores con programas reales.
Si hay un plan nacional para reducir impacto de ransomware en sanidad, escoge métricas ATT&CK que miren credenciales, movimiento lateral, exfiltración e impacto en ese sector.[web:66][web:61]
3. Asegura la explicación hacia arriba y hacia abajo.
4. Hacia arriba: gráficos claros, poco texto, foco en riesgo y tendencia.
5. Hacia abajo: detalle técnico, heatmaps ATT&CK, lecciones aprendidas por técnica y táctica.[web:23][web:16]
6. Acepta que la precisión absoluta es una quimera.
Es mejor un indicador honesto y ligeramente impreciso que uno exacto pero irrelevante.
La honestidad estadística suele ser más barata que las auditorías post mortem.

No medirlo todo a la vez.

Empieza con 3–5 indicadores de alta puntuación PRAGMATIC (por ejemplo, cobertura de técnicas relevantes, MTTD/MTTR en cadenas críticas y brecha declarada/validada).

Alinea los indicadores con programas reales.

Si hay un plan nacional para reducir impacto de ransomware en sanidad, escoge métricas ATT&CK que miren credenciales, movimiento lateral, exfiltración e impacto en ese sector.[web:66][web:61]

Asegura la explicación hacia arriba y hacia abajo.

Hacia abajo: detalle técnico, heatmaps ATT&CK, lecciones aprendidas por técnica y táctica.[web:23]
[web:16]

Acepta que la precisión absoluta es una quimera.

Es mejor un indicador honesto y ligeramente impreciso que uno exacto pero irrelevante.

La honestidad estadística suele ser más barata que las auditorías post mortem.

6. La moraleja

La combinación de GQM y PRAGMATIC aplicada a MITRE ATT&CK y al contexto europeo de amenazas no es un ejercicio académico; es la forma más razonable de:

- Conectar declaraciones de resiliencia nacional con logs, alertas y playbooks.
- Poner orden en el zoo de métricas potenciales para quedarse con las pocas que importan.
- Recordar que medir sin propósito es contabilidad cósmica, y que ningún adversario ha sido detenido todavía por un KPI muy bien maquettato.

El valor real llegará cuando las decisiones de inversión, las prioridades del SOC y las estrategias nacionales empiecen a compartir las mismas palabras: tácticas, técnicas, tiempos... y, sí, también costes y retornos.